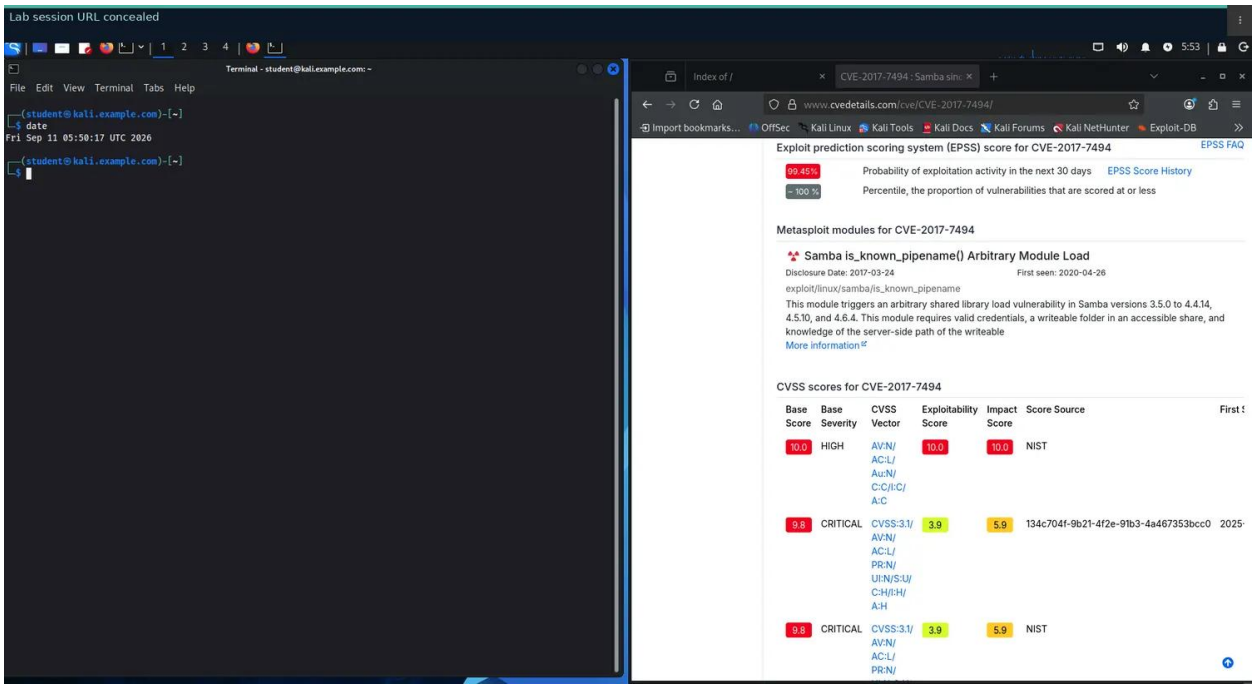
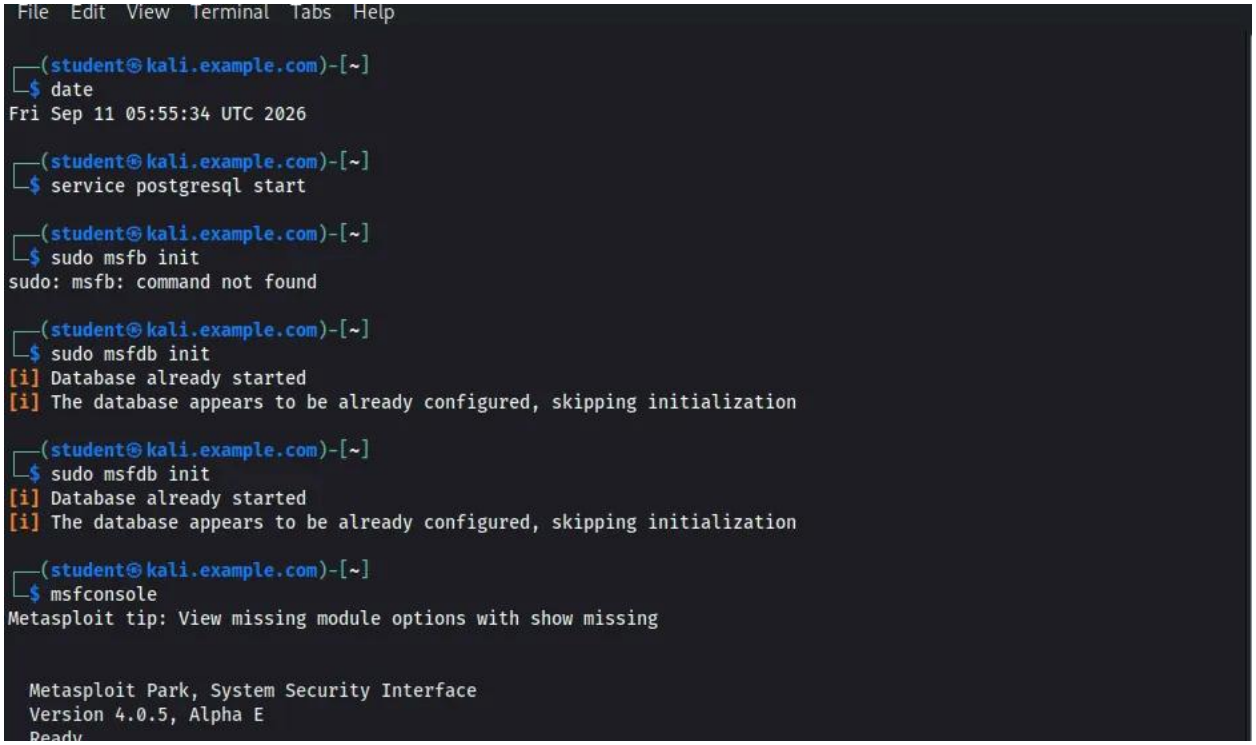
CYSE 425 - Lab 1

Harshith Motipalli
Professor Gebril

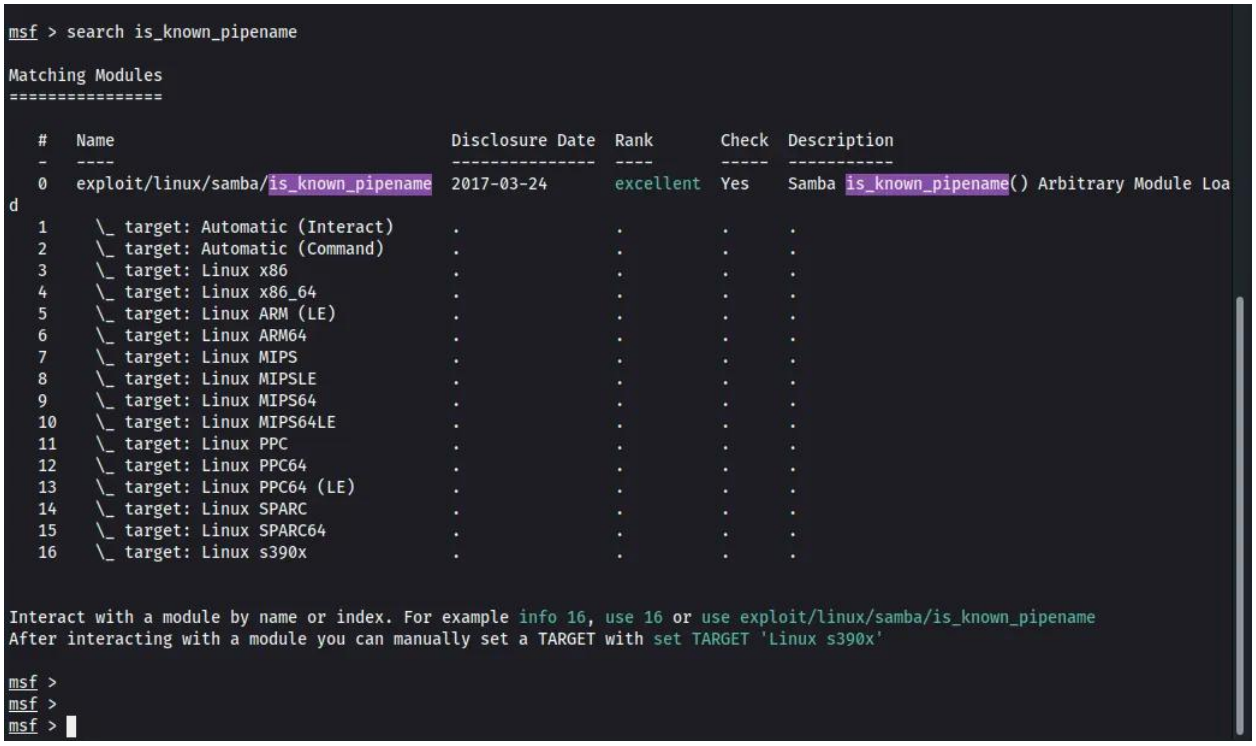
Exploitation:



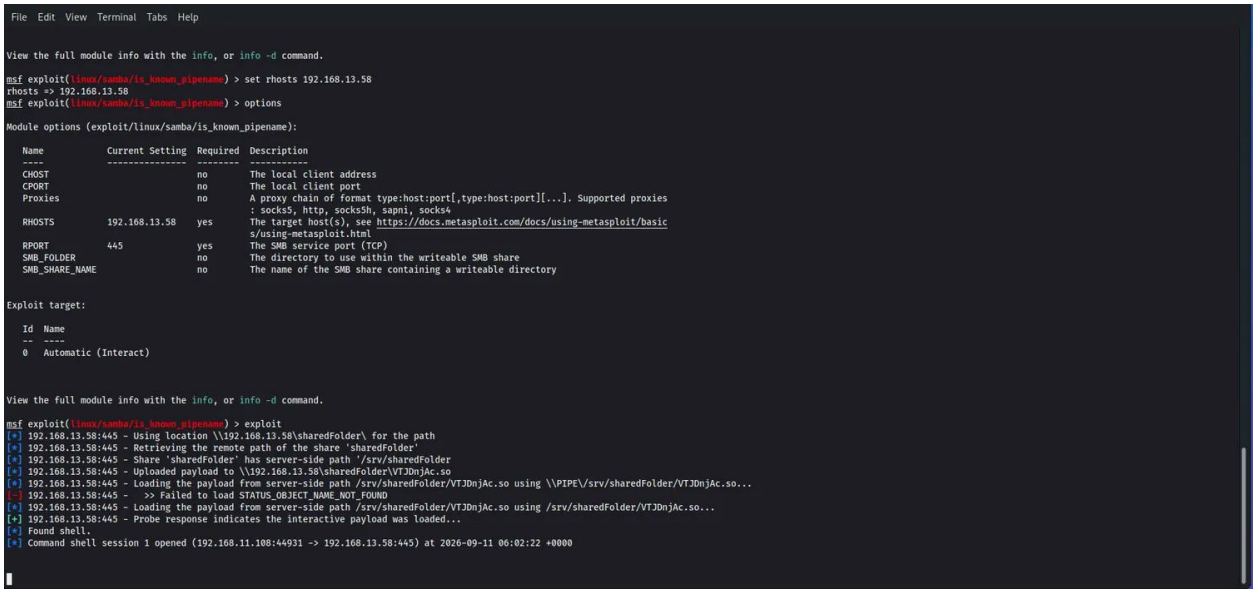
Metasploit was launched in Kali Linux to begin the authorized exploitation of the vulnerable Samba target



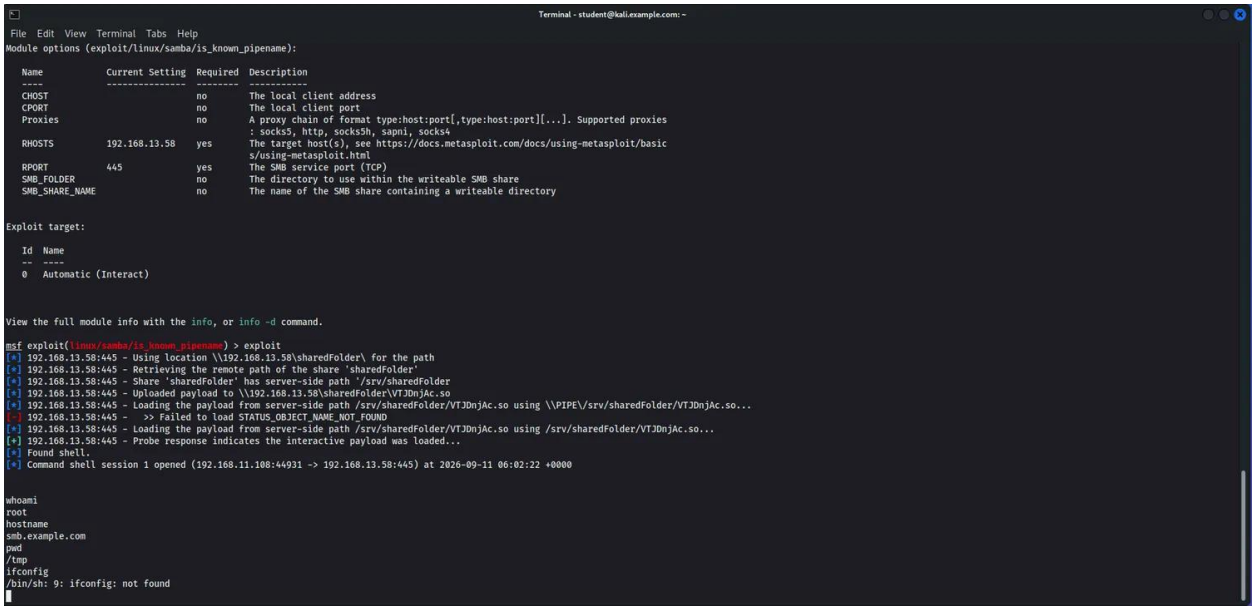
The is_known_pipeline Metasploit module associated with Samba vulnerability CVE-2017-7494 was identified for the authorized lab assessment.



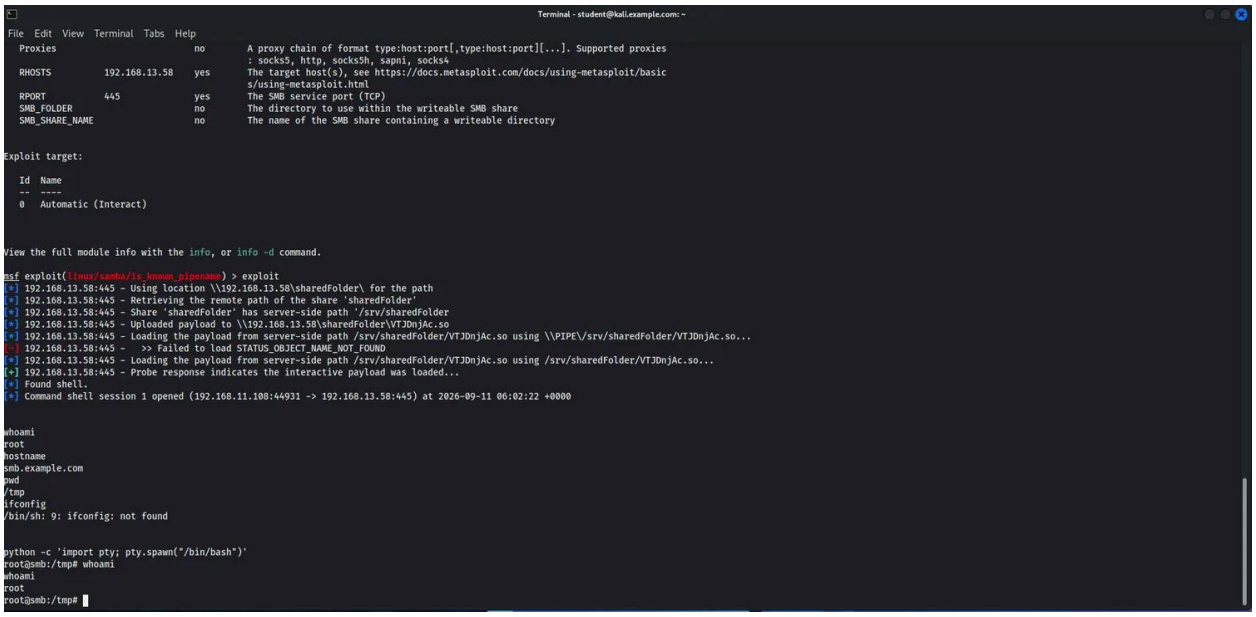
The Samba exploit module was selected and configured with the target system's IP address



The exploit was executed against the authorized target to attempt remote command-shell access.

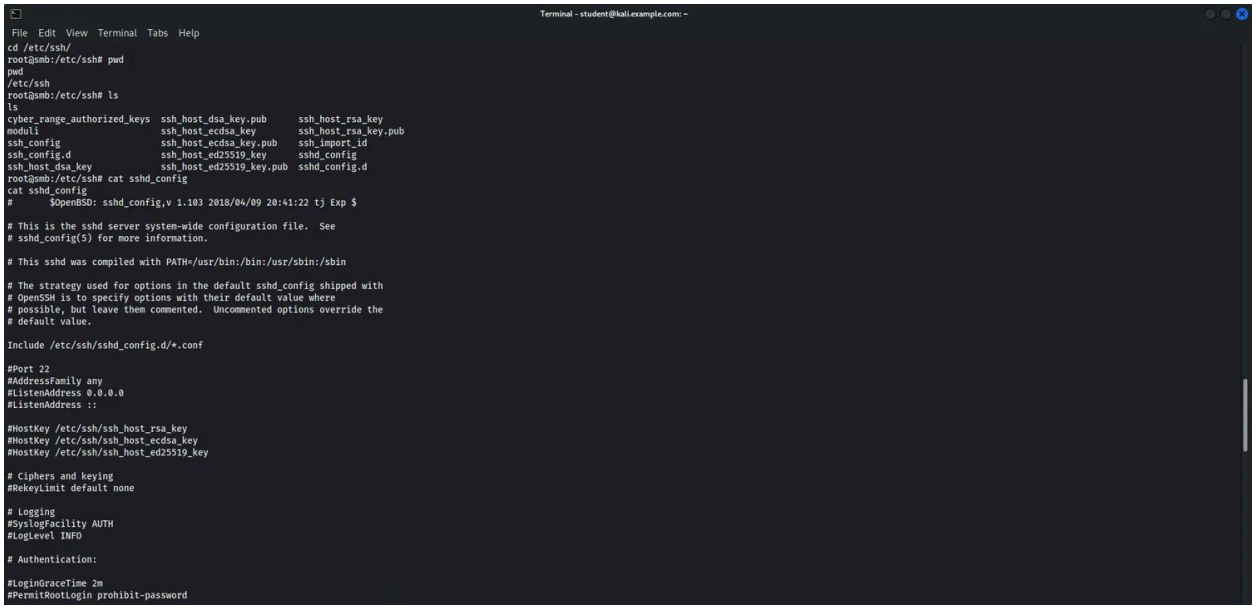


A command-shell session was successfully opened on the target following exploitation of the Samba vulnerability

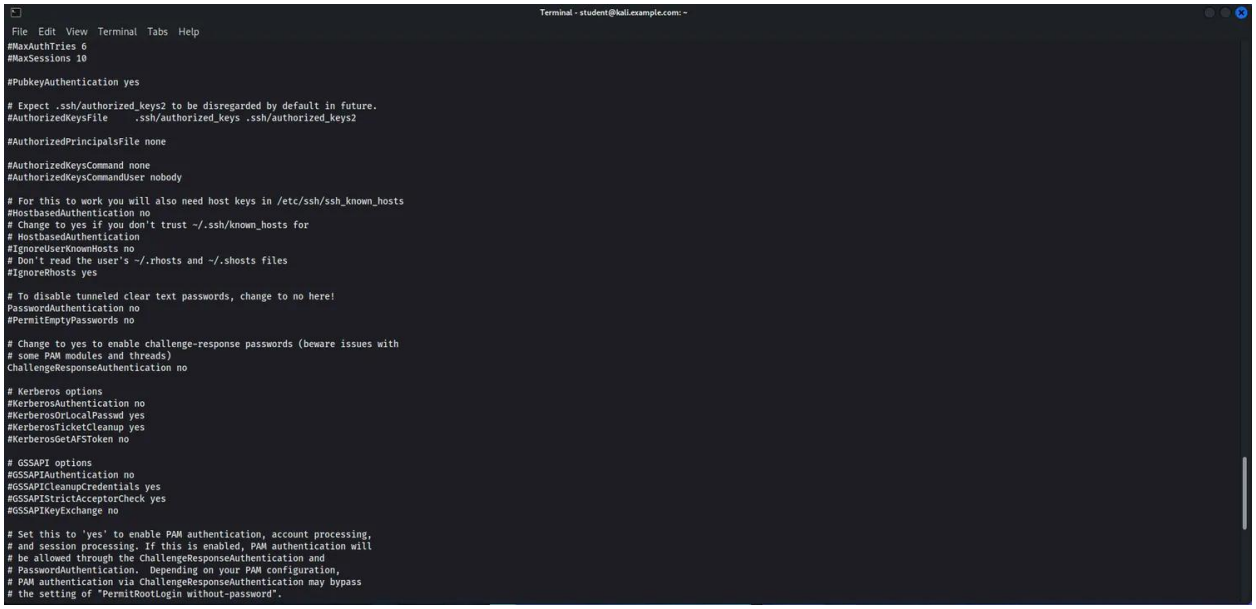


The whoami command confirmed that the exploit provided root-level access on the target system

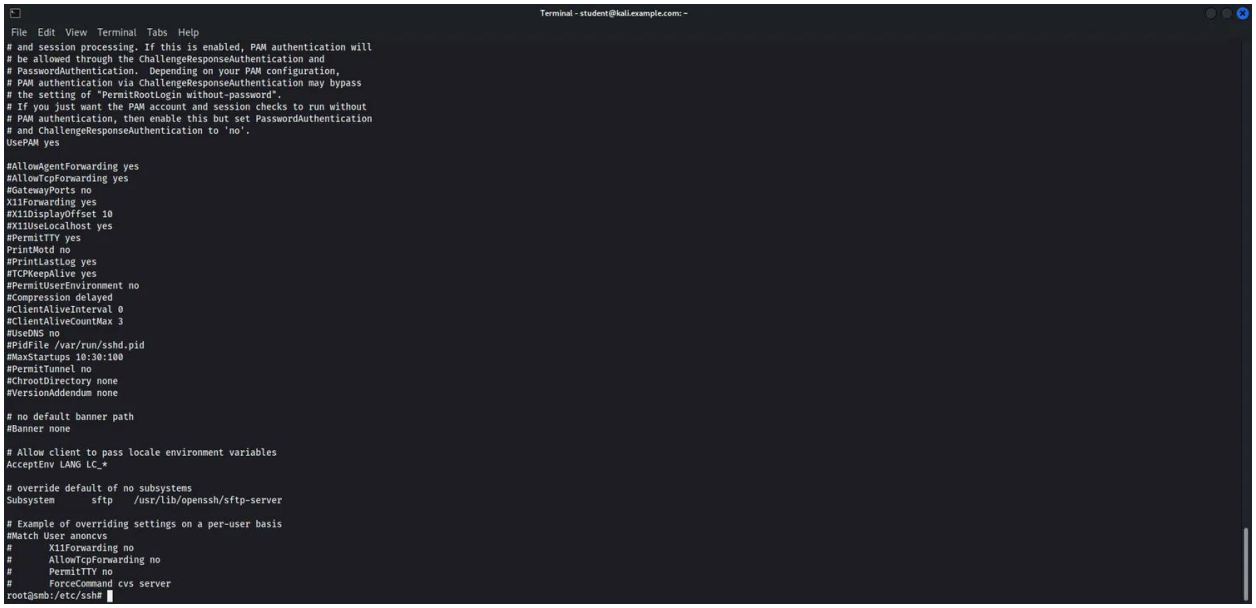
Post Exploitation:



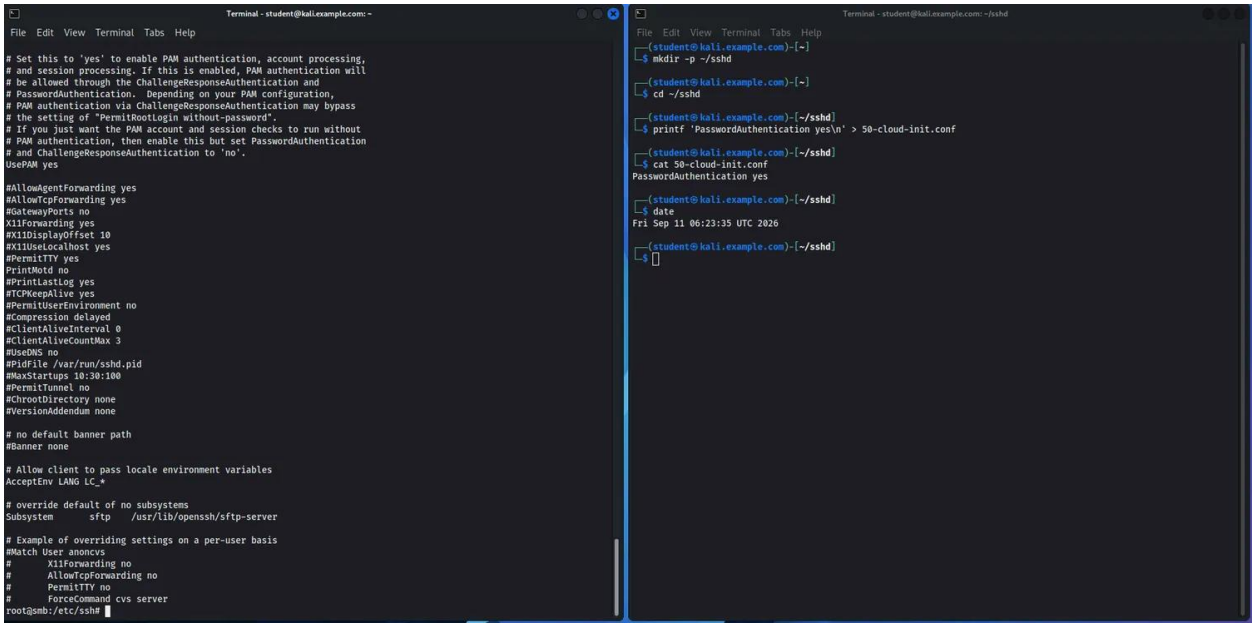
The SSH server configuration on the target was reviewed to identify the password-authentication setting



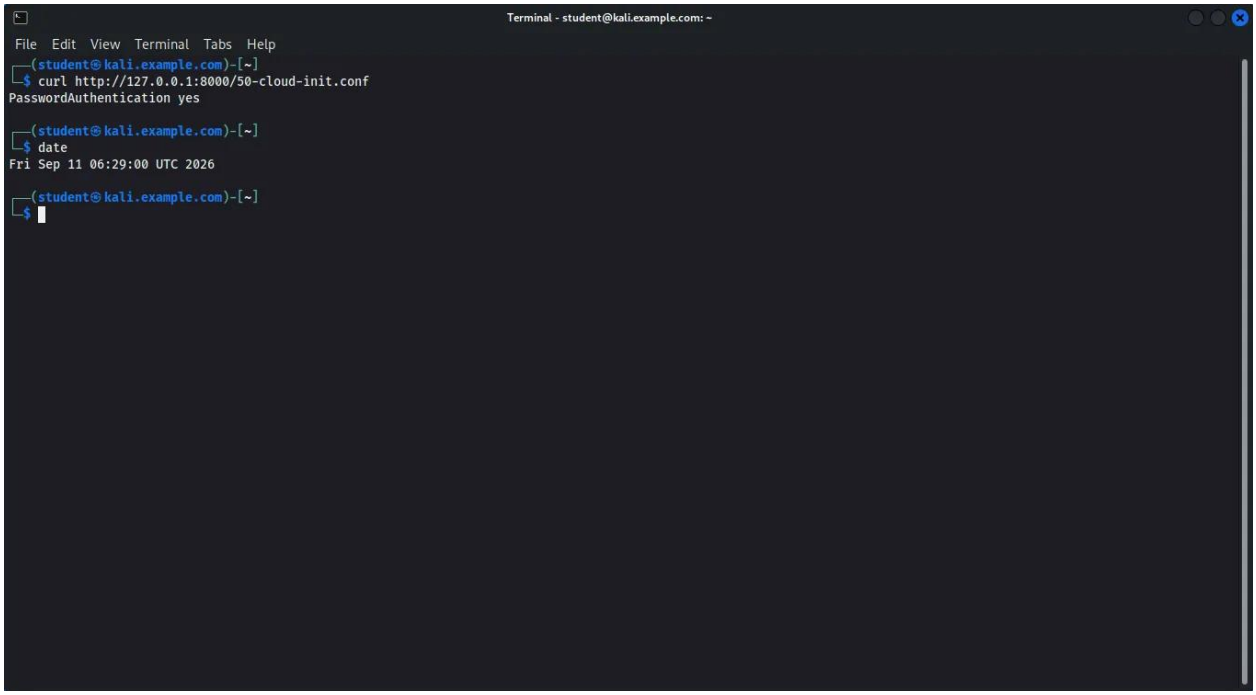
The SSH configuration was temporarily modified in the authorized lab environment to permit password-based authentication



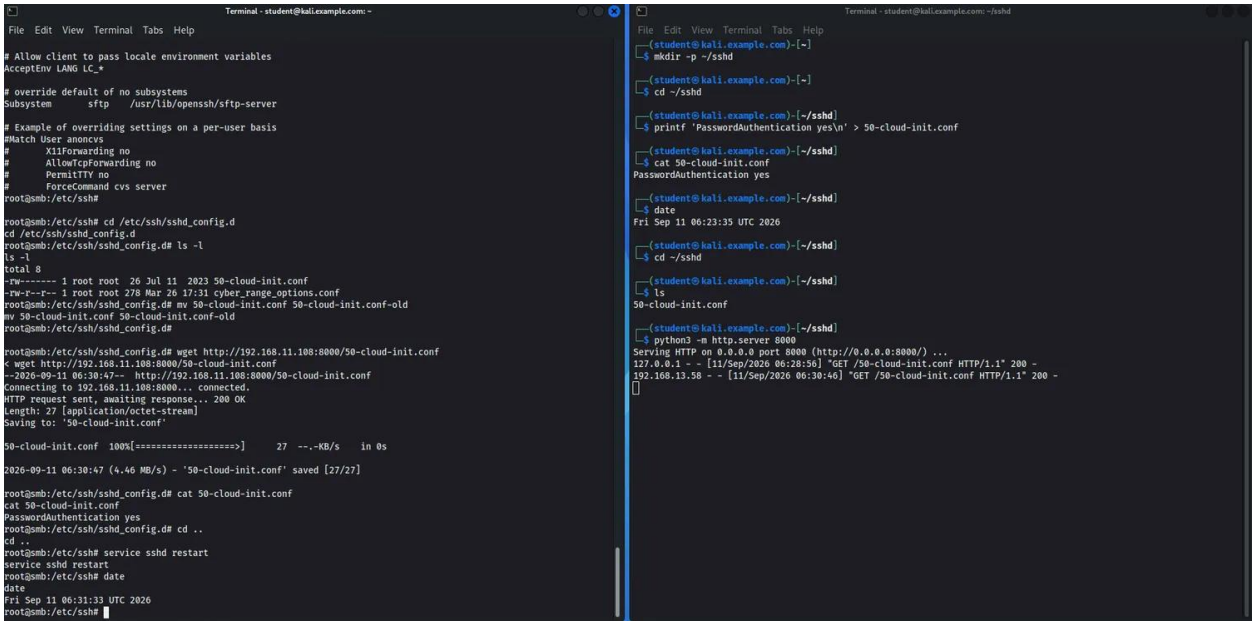
The modified SSH configuration was prepared on Kali before being transferred back to the target system



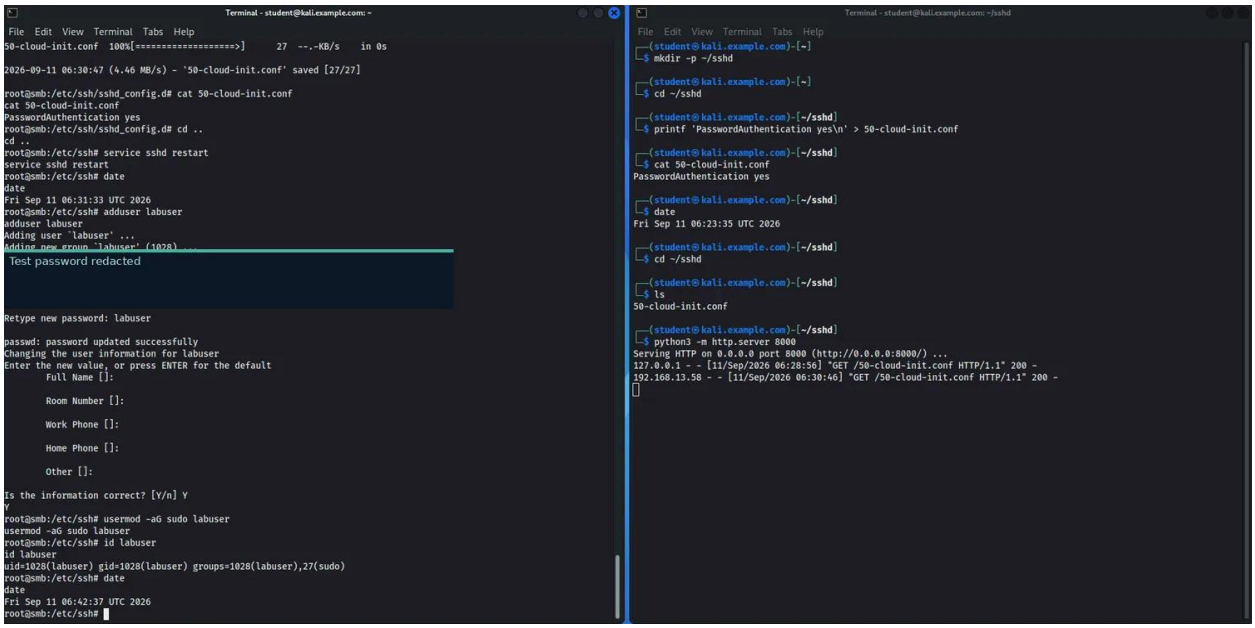
A local HTTP service was started on Kali to make the modified SSH configuration available to the target



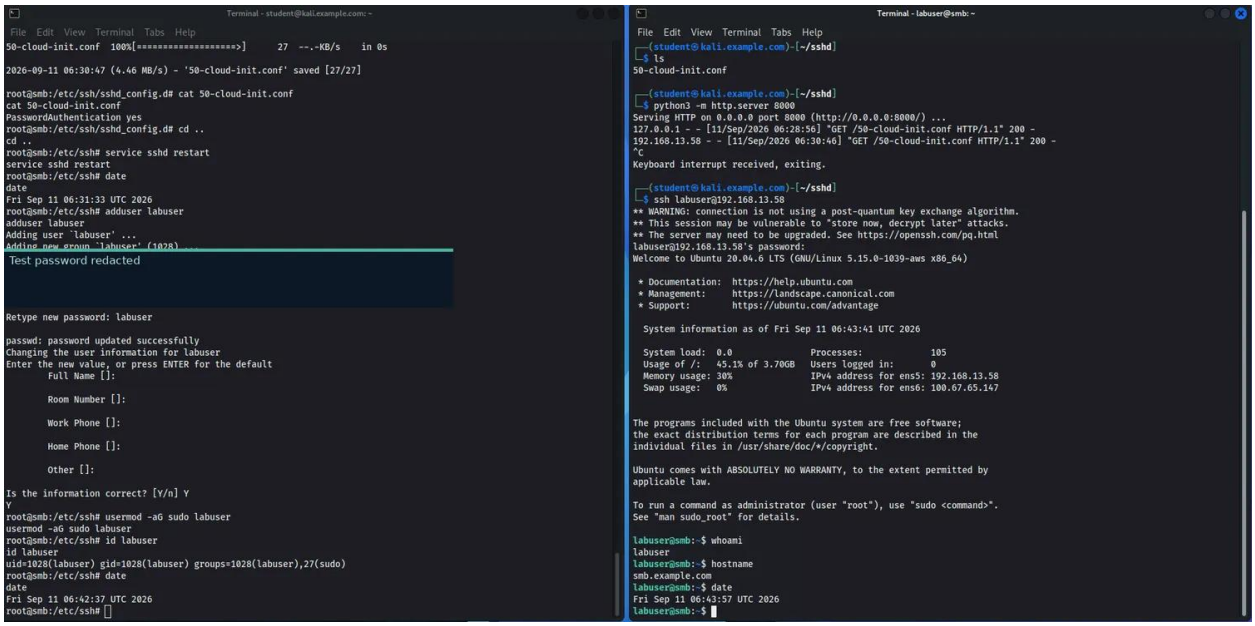
The target downloaded the modified SSH configuration from Kali and replaced the prior configuration for the lab exercise



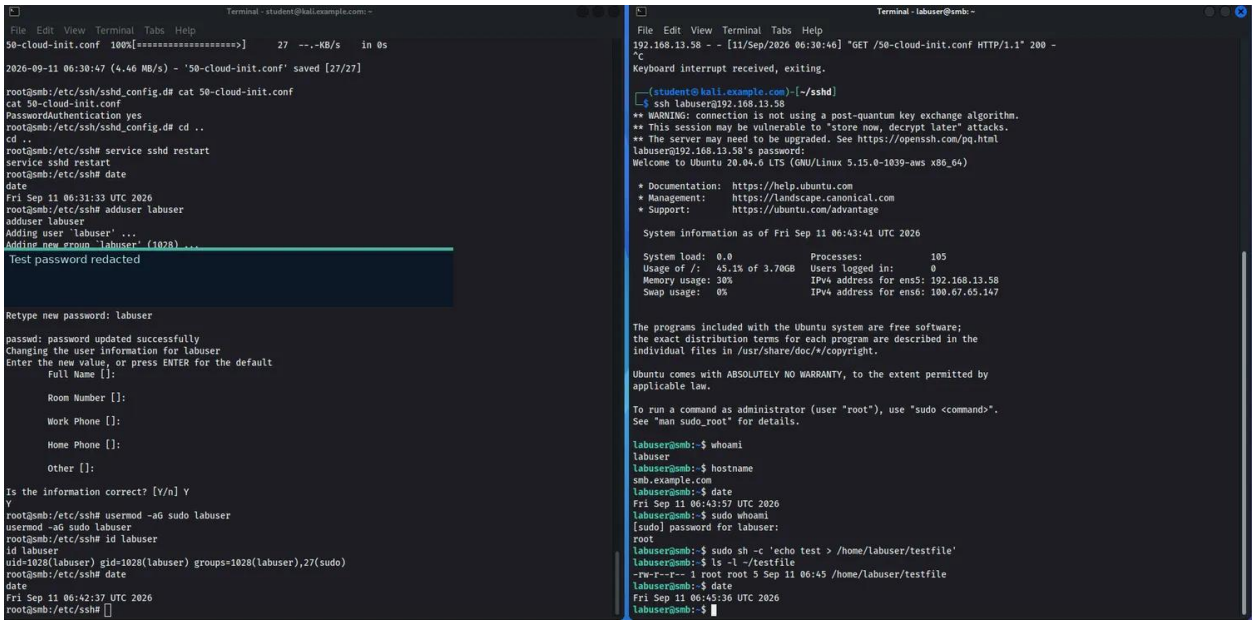
The SSH service was restarted to apply the temporary password-authentication configuration



A temporary lab user account was created on the target to demonstrate authenticated remote access

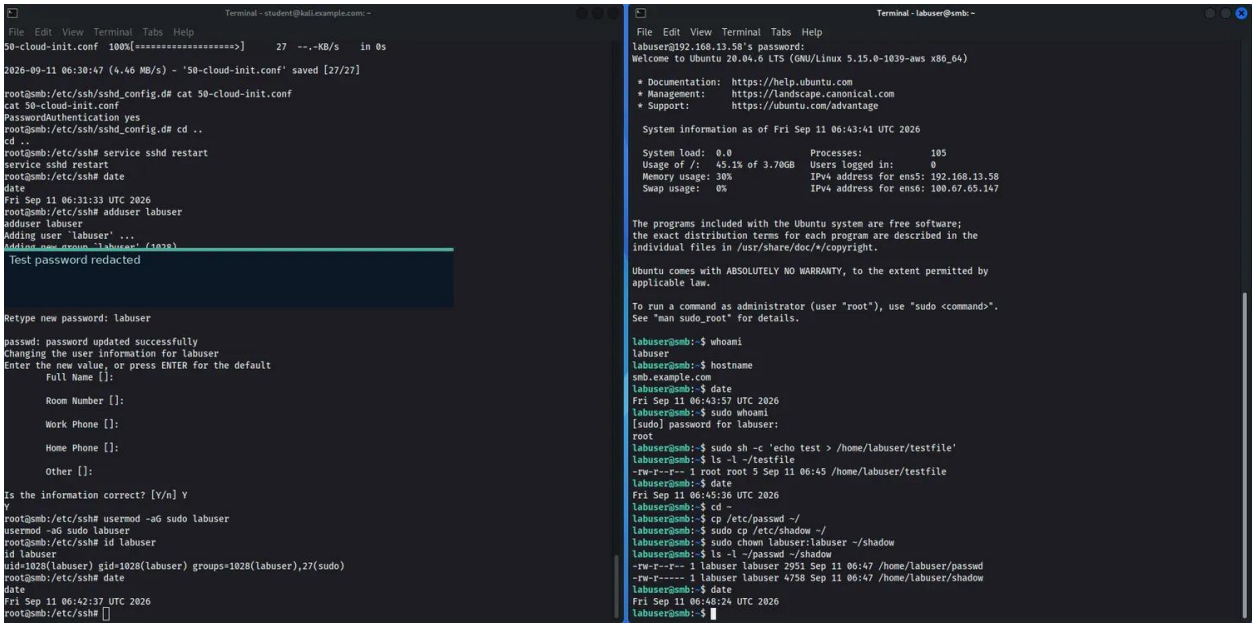


The temporary lab account was granted sudo privileges for authorized administrative testing

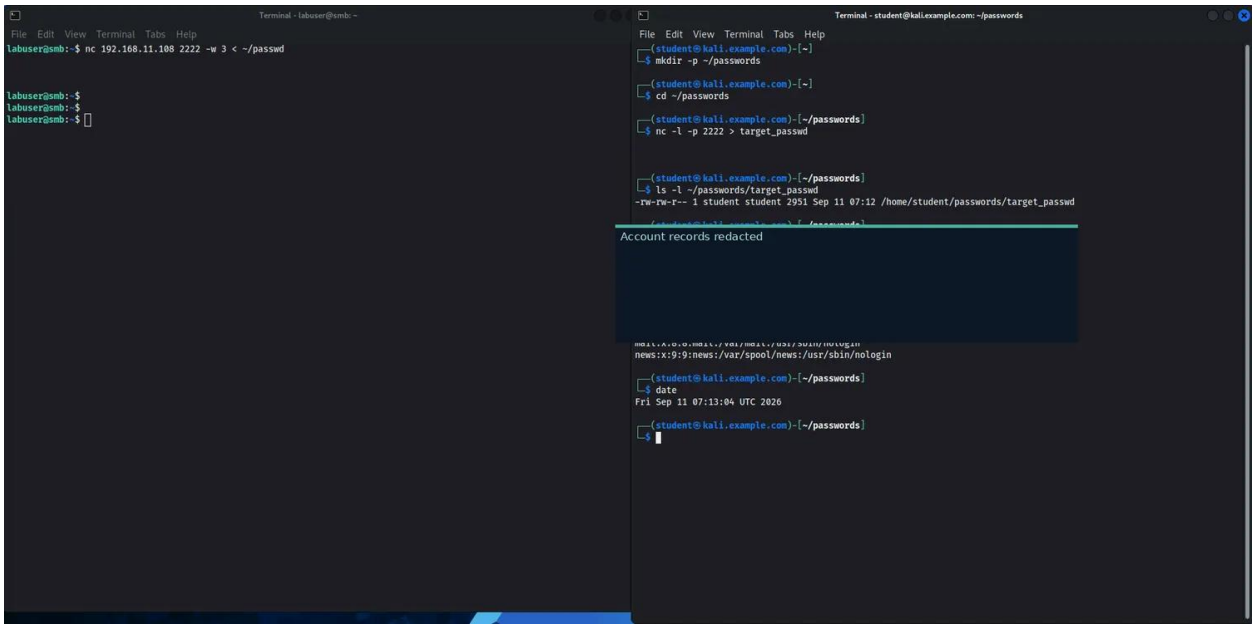


SSH login and sudo access were successfully verified using the temporary privileged lab account

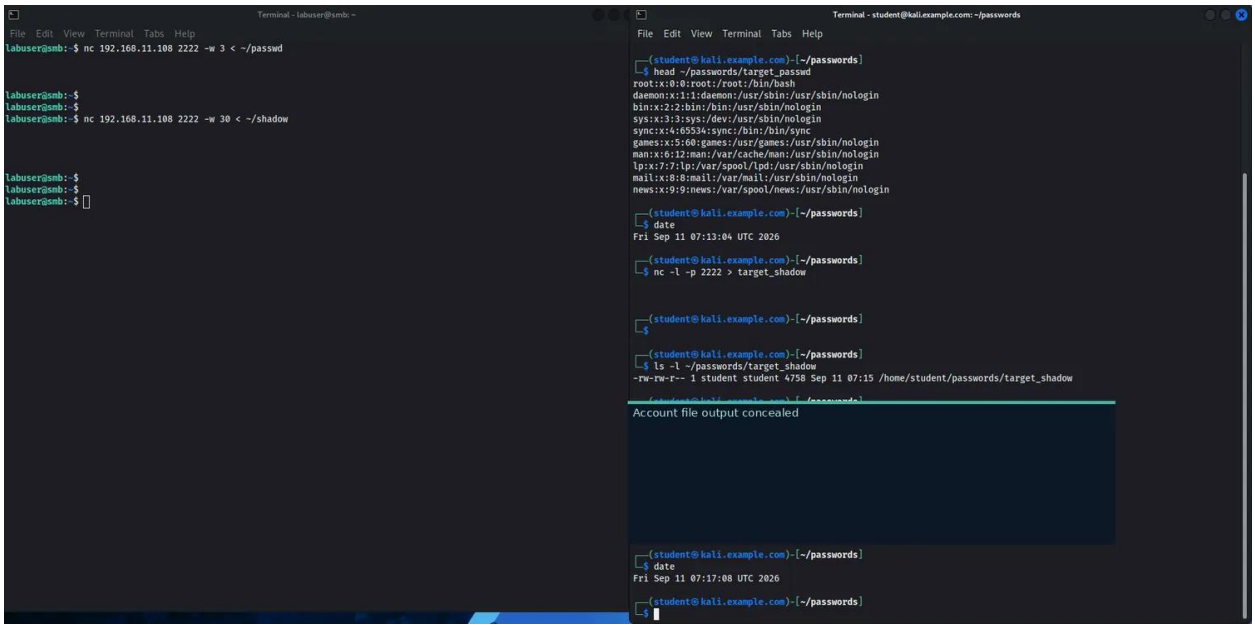
Exfiltration:



Authorized copies of the target's account-information files were created in the temporary lab user's home directory

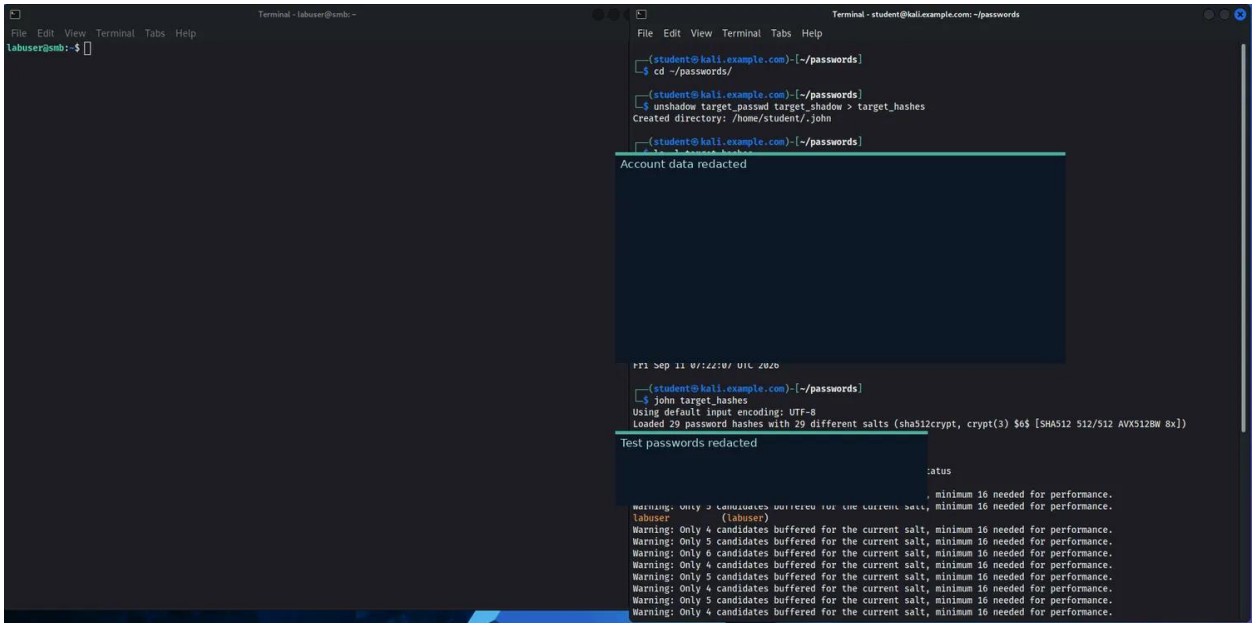


A Netcat listener was started on Kali to receive the authorized passwd file from the target

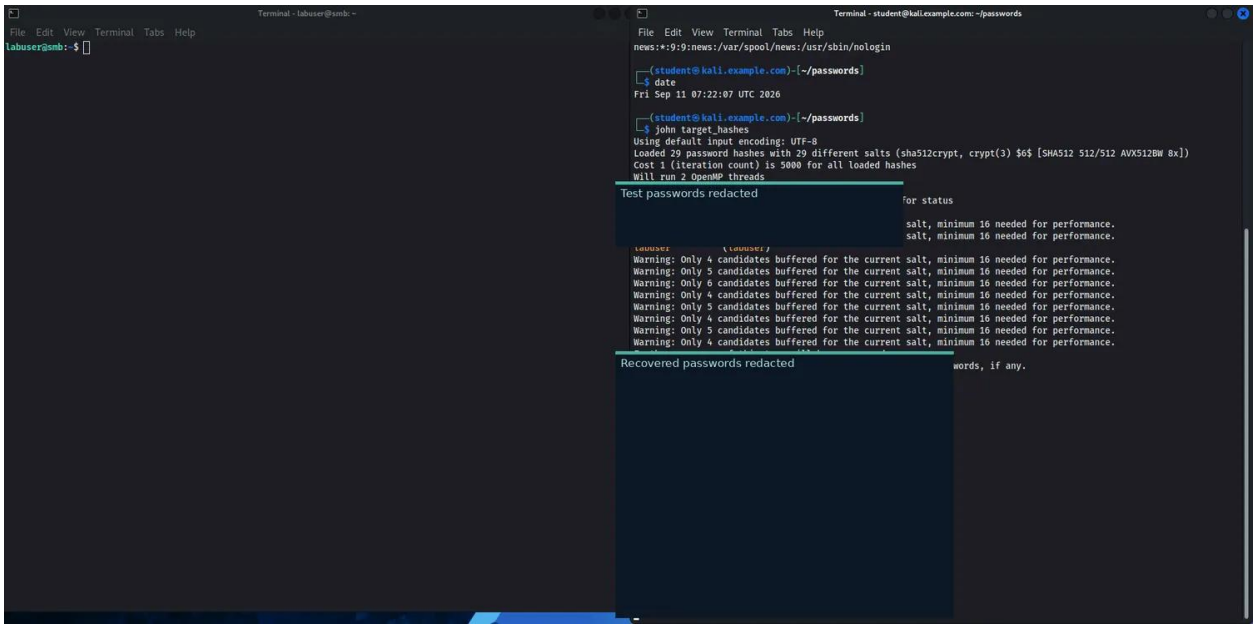


The passwd and shadow test files were successfully transferred to Kali and verified with terminal output

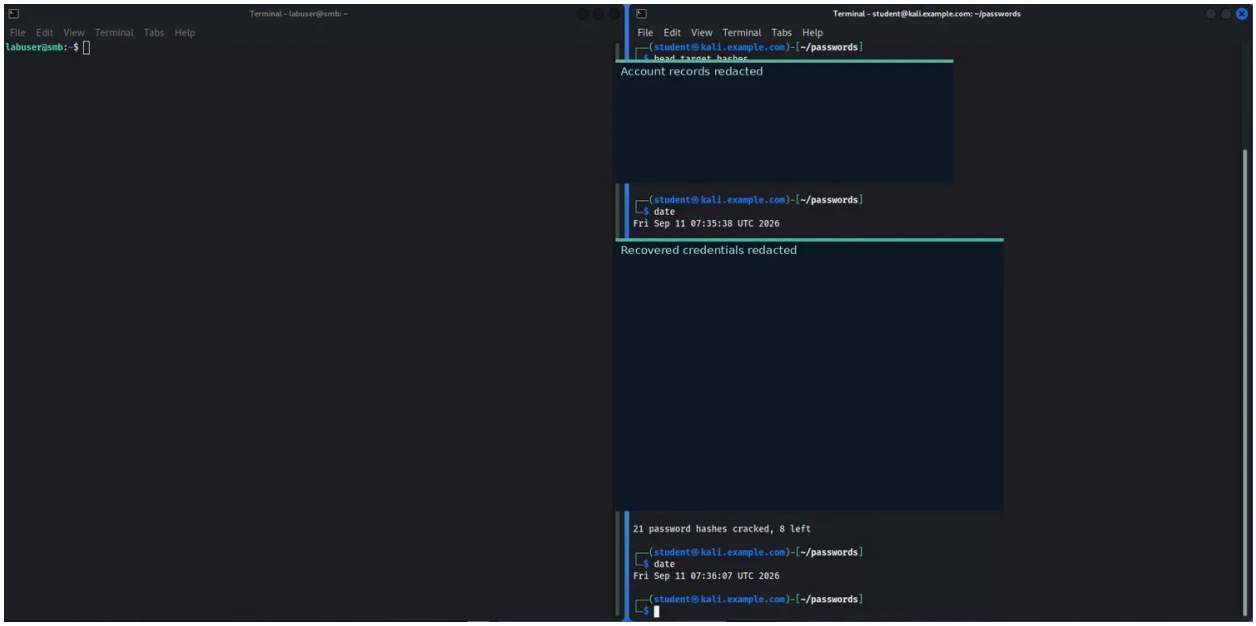
Password Cracking:



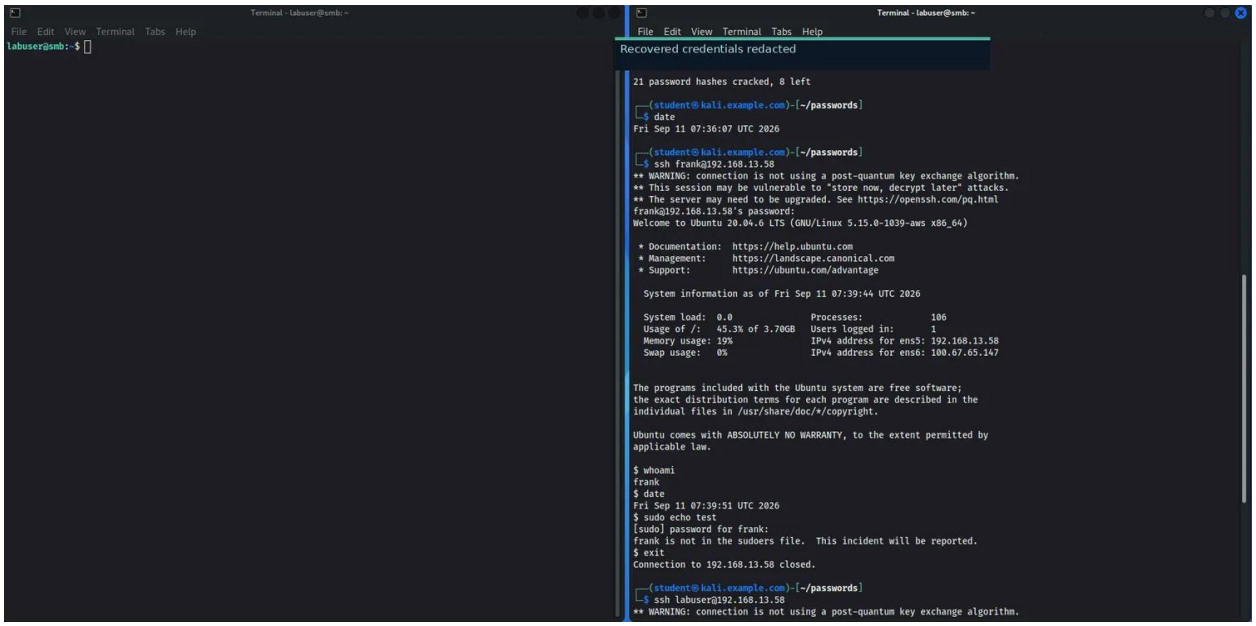
The unshadow command combined the authorized passwd and shadow files into a password-hash file for analysis



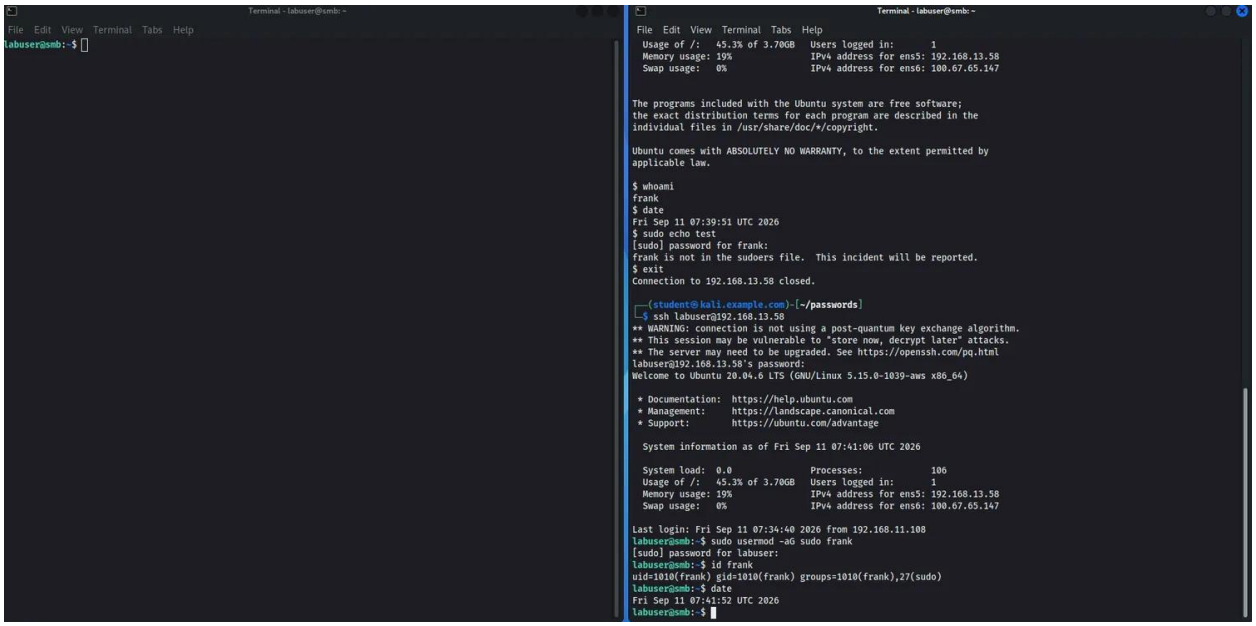
John the Ripper was run against the authorized hash file to demonstrate the security risk of weak passwords



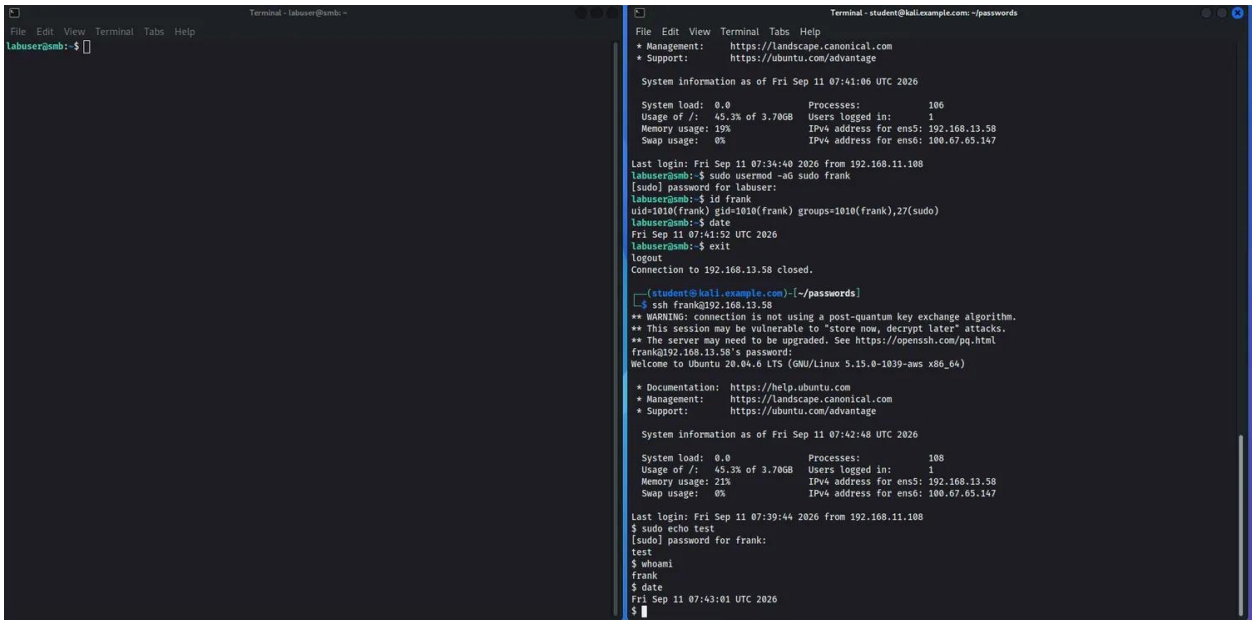
John the Ripper displayed recovered test-account credentials from the password-hash analysis



A recovered test account successfully authenticated to the target system through SSH

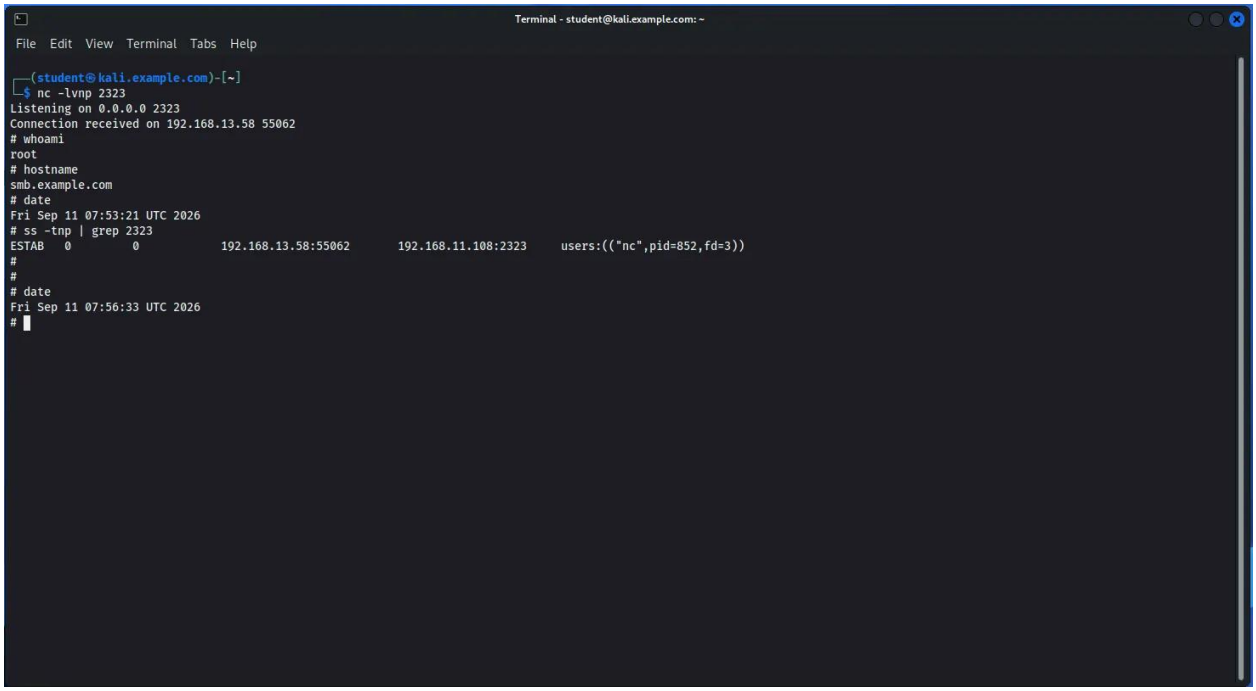


The whoami command confirmed the identity of the recovered account after successful SSH authentication



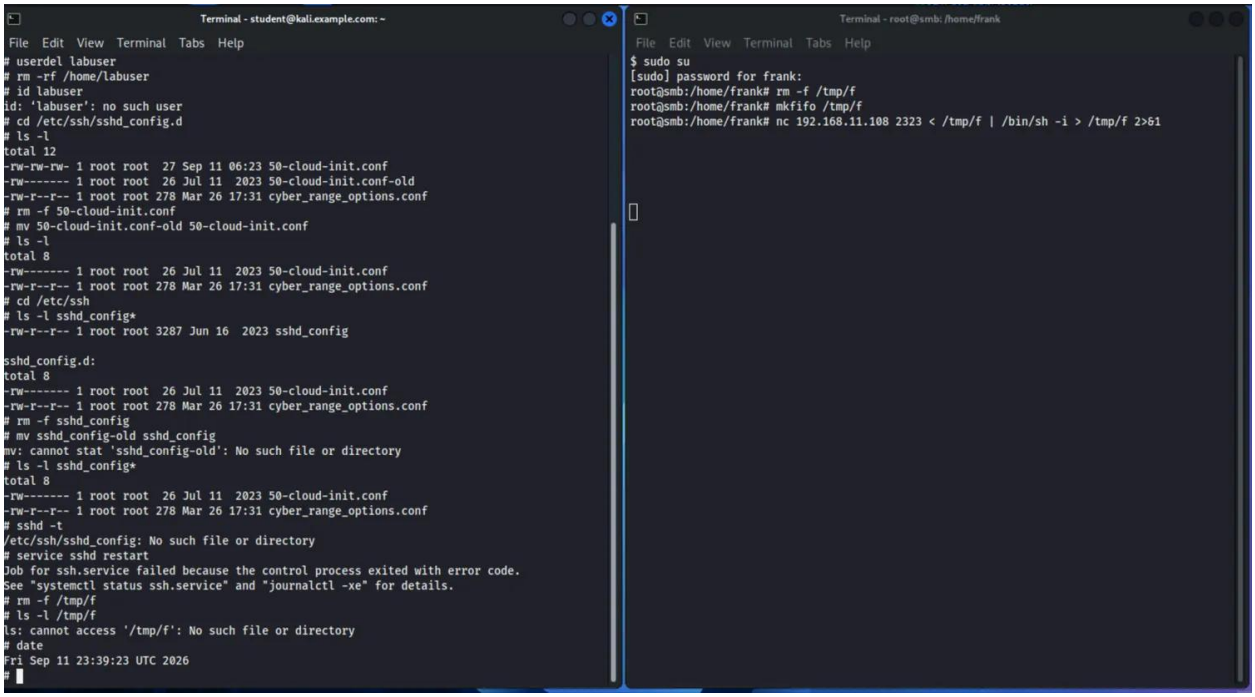
The sudo echo test command confirmed that the recovered test account could execute authorized administrative commands

Creating a Backdoor:



The Kali Netcat listener received an authorized reverse-shell connection from the target, and root access to smb.example.com was verified

Cleaning Up:



The temporary lab account, modified SSH configuration files, and reverse shell artifact were removed to restore the target system to its original state